Practice Questions

Candidate: Dunkan Gibson (dunkan.gibson)
Date: 11/15/2021 7:53:55 pm • Time spent: 03:42

Score: 100% Passing Score: 80%

Question 1: ✔ Correct

As you are helping a user with a computer problem, you notice that she has written her password on a note stuck to her computer monitor. You check the password policy of your company and find that the following settings are currently required:

- Minimum password length = 10
- Minimum password age = 4
- Maximum password age = 30
- Password history = 6
- Account lockout clipping level = 3
- Require complex passwords that include numbers and symbols

Which of the following is the best action to take to make remembering passwords easier so that she no longer has to write the password down?

- ➡ ◉ Implement end-user training.
- ○ Increase the maximum password age.
- ○ Increase the account lockout clipping level.
- ○ Decrease the minimum password length.
- ○ Remove the complex password requirement.

EXPLANATION

The best solution is to implement end-user training. Instruct users on the importance of security and teach them how to create and remember complex passwords. Making any other changes would violate the security policy and reduce the overall security of the passwords.

REFERENCES

LabSim for Network Pro, Section 13.4.

Question 2: ✔ Correct

A user named Bob Smith has been assigned a new desktop workstation to complete his day-to-day work. The computer runs Windows 7.

When provisioning Bob's user account in your organization's domain, you assigned an account name of **BSmith** with an initial password of **bw2Fs3d**.

At his first logon, Bob is prompted to change his password, so he changes it to **Fido**, the name of his dog.

What should you do to increase the security of Bob's account? (Select two.)

- [x] Require users to set a stronger password upon initial logon.
- [ ] Configure user account names that are not easy to guess.
- [x] Train users not to use passwords that are easy to guess.
- [ ] Upgrade the workstation to Windows 8.
- [ ] Do not allow users to change their own passwords.

EXPLANATION

In this scenario, a weak password that is easy to guess has been used. To prevent this from happening, you should:

- Require strong passwords on user accounts. In this example, **Fido** is a weak password because it is short and doesn't contain numbers or other non-alphabetic characters.
- Train users not to use passwords that are easy to guess. In this example, the user's password could very likely be guessed using basic reconnaissance techniques on social media websites.

You should allow users to set their own passwords. If you don't, then both the administrator and the user know the password, which is a poor security practice. Using the type of user account names that are shown in this scenario is generally considered an acceptable security practice. The security provided by Windows 7 is comparable to that provided by Windows 8.

REFERENCES

LabSim for Network Pro, Section 13.4.

Question 3: ✔ Correct

In a variation of a brute force attack, an attacker may use a predefined list (dictionary) of common usernames and passwords to gain access to existing user accounts. Which countermeasure best addresses this issue?

- AES encryption
- VLANs
- ➡ A strong password policy
- 3DES encryption

EXPLANATION

A strong password policy is the best defense against dictionary attacks. The policy must be enforced, and all users must be trained to properly construct and protect strong passwords.

3DES and AES encryption alone do not adequately prevent dictionary attacks. Encryption technologies are useless if weak passwords permit easy access to encrypted channels.

VLANs allow logical segmentation of a physical network and do not prevent dictionary attacks and weak passwords.

REFERENCES

LabSim for Network Pro, Section 13.4.

Question 4: ✔ Correct

Which of the following attacks is a form of software exploitation that transmits or submits a longer stream of data than the input variable is designed to handle?

- Smurf
- Time of check/time of use (TOC/TOU)
- ➡ Buffer overflow
- Data diddling

EXPLANATION

A buffer overflow occurs when software code receives more input than it was designed to handle and the code's programmer failed to include input validation checks. When a buffer overflow occurs, the extra data is pushed into the execution stack and processed with the security context of the system itself. In other words, a buffer overflow attack often allows the attacker to perform any operation on a system.

TOC/TOU is an attack where the results of the attack are realized or initiated at a time or event after the attack itself is perpetrated. Data diddling is the purposeful altering of data. A smurf attack is a form of distributed reflective denial of service.

REFERENCES

LabSim for Network Pro, Section 13.4.

Question 5: ✔ Correct

While using a web-based order form, an attacker enters an unusually large value in the quantity field.

The value entered is large enough to exceed the maximum value supported by the variable type used to store the quantity in the web application. This causes the value of the quantity variable to wrap around to the minimum possible value, which is a negative number.

As a result, the web application processes the order as a return instead of a purchase, and the attacker's account is refunded a large sum of money.

What type of attack has occurred in this scenario?

- URL hijacking
- Watering hole
- ➡ Integer overflow
- Buffer overflow

EXPLANATION

An integer overflow occurs when a computational operation results in a numeric value that exceeds the maximum size of the integer type used to store it in memory. When this occurs, the value will wrap around and start again at its minimum value in much the same way a mechanical odometer in a car rolls over to zero when the maximum number of miles it can record has been exceeded. This allows an attacker to manipulate the value of variables, leading to unintended system behavior. In this scenario, the attacker has manipulated the quantity while purchasing items from an online store. This causes the value of the quantity variable to wrap around to the minimum possible value, which is a negative number. As a result, the web application processes the order form as a return instead of a purchase, and the attacker's account is refunded a large sum of money.

A buffer overflow occurs when the operating system or an application does not properly enforce boundaries for how much and what type of data can be input. In a watering hole attack, the attacker uses reconnaissance to identify which websites the target person or organization frequently uses. The attacker then compromises one or more of those sites in some way, hoping that the target will access the site and become exposed to the exploit. URL hijacking occurs when an attacker registers domain names that correlate to common typographical errors users make when trying to access a legitimate website.

REFERENCES

LabSim for Network Pro, Section 13.4.

Question 6: ✔ Correct

Which of the following is a text file that a website stores on a client's hard drive to track and record information about the user?

- ➡ (●) Cookie
- ( ) Mobile code
- ( ) Certificate
- ( ) Digital signature

EXPLANATION

A cookie is a text file that a website provides to a client that is stored on a user's hard drive to track and record information about the user.

Mobile code is self-contained software that is transferred to a web client to be executed. It allows client-side execution of web applications. A certificate is a digital proof of identity used to establish or verify a user's identity over a network or the internet. A digital signature is a cryptographic tool that is used to prove who a message is from and that the contents of the message did not change or become altered while in transit.

REFERENCES

LabSim for Network Pro, Section 13.4.

Question 7: ✔ Correct

When you browse to a website, a pop-up window tells you that your computer has been infected with a virus. You click on the window to see what the problem is. Later, you find out that the window has installed spyware on your system.

What type of attack has occurred?

- DLL injection
- ➡ Drive-by download
- Trojan horse
- SQL injection

EXPLANATION

A drive-by download is an attack where software or malware is downloaded and installed without explicit consent from the user. Drive-by downloads can occur in a few different ways:

- Through social engineering, the user is tricked into downloading the software. The user might not realize that clicking a link will install software, or the user might know that something is being installed, but not have a full understanding of what it is or what it does.
- By exploiting a browser or operating system bug, a site is able to install software without the user's knowledge or consent.

An SQL injection attack occurs when an attacker includes database commands within user data input fields on a form, and those commands subsequently execute on the server. A DLL injection attack occurs when a program is forced to load a dynamic-link library (DLL). This DLL then executes under the security context of the running application, which executes malicious code included with the injected DLL. A Trojan horse is a program that masquerades as a legitimate program. In this scenario, you were not necessarily aware that a program was being installed, nor did the program present itself as a useful program for you to install.

REFERENCES

LabSim for Network Pro, Section 13.4.

Question 8: ✔ Correct

You've just deployed a new Cisco router that connects several network segments in your organization.

The router is physically located in a server room that requires an ID card for entry. You've backed up the router configuration to a remote location in an encrypted file. You access the router configuration interface from your notebook computer by connecting it to the console port on the router. You configured the management interface with the username **admin** and the password **password**.

What should you do to increase the security of this device?

- Use a web browser to access the router configuration using an HTTP connection.
- Use an SSH client to access the router configuration.
- ➡ Use a stronger administrative password.
- Move the device to a secure data center.

EXPLANATION

In this scenario, the password assigned to the device is weak and easily guessed. It should be replaced with a strong password that is at least eight characters long, uses upper- and lower-case letters, and uses numbers or symbols.

Using HTTP to manage the router configuration could expose sensitive information to sniffers, as it transmits data in clear text. Using the console port to access the device creates a dedicated connection, making the use of SSH unnecessary. Because the device has been installed in a secured room, it's not necessary to move it to a data center.

REFERENCES

LabSim for Network Pro, Section 13.4.

Question 9: ✔ Correct

Which of the following attacks, if successful, causes a switch to function like a hub?

- Replay
- ARP poisoning
- MAC spoofing
- ➡ MAC flooding

EXPLANATION

MAC flooding overloads the switch's MAC forwarding table to make the switch function like a hub. The attacker floods the switch with packets, each containing different source MAC addresses. The flood of packets fills up the forwarding table and consumes so much of the memory in the switch that it causes the switch to enter a state called failopen mode, in which all incoming packets are broadcast out all ports (as with a hub), instead of just to the correct ports, as per normal operation.

ARP poisoning associates the attacker's MAC address with the IP address of victim devices. When computers send an ARP request to get the MAC address of a known IP address, the attacker's system responds with its MAC address. MAC spoofing is changing the source MAC address on frames sent by the attacker.

In a replay attack, the attacker uses a protocol analyzer or sniffer to capture authentication information going from the client to the server. The attacker then uses this information to connect at a later time and pretend to be the client.

REFERENCES

LabSim for Network Pro, Section 13.4.

Question 10: ✔ Correct

You want to prevent your browser from running JavaScript commands that are potentially harmful. Which of the following would you restrict to accomplish this?

- CGI
- ActiveX
- ➡ Client-side scripts
- Server-side scripts

EXPLANATION

JavaScript is an example of client-side scripting, where the client system runs the scripts that are embedded in web pages. When pages download, the scripts are executed.

ActiveX runs executable code within a browser, but ActiveX controls are not written using the JavaScript language. Server-side scripts execute on the server and modify the Web pages served to clients based on the results of the scripts. The Common Gateway Interface (CGI) is scripting language that is often used to capture data from forms in a web page and pass the data to an external program. CGI runs on the server to process web form data.

REFERENCES

LabSim for Network Pro, Section 13.4.

Copyright © 2021 TestOut Corporation All rights reserved.